CONFIDENTIAL. PREPARED TO OBTAIN LEGAL ADVICE.

# Kestrel Eye Care Jobs

## Legal review pack: business, privacy and technology

For a fixed fee review meeting. Everything that needs a lawyer's eyes is in this one document: what the business is, the questions in order of priority, and the documents themselves.

Prepared on 31st October 2026 by Steve Smith, founder, from an audit of the website and its code carried out on 30th October 2026.
The legal references in this pack are an AI assistant's reading and were not checked by a lawyer. Where it is unsure, it says so. Please verify them.

**How to use this pack.** Part 1 is the plain summary. Parts B to G are questions 7 to 41, in the order I would like to cover them. If time is short, Parts B and C come first and the rest can follow by email. Questions 1 to 6 are about employment and are being handled separately. The two background sections after Part G describe what the site collects and what has already been decided. The appendices are the policies exactly as they are published today, the breach plan, the consent wordings and the email list.

# Part 1. The business in one page

**What it is.** Kestrel Eye Care Jobs (eyecarejobs.ca) is a self serve job board for Canadian eye care: optometrists, opticians, optometric assistants and technicians, practice managers, patient care teams and, later, supplier representatives and locums. Independent and corporate practices post side by side. Candidates search free; clinics pay to post.

**Where it stands.** Not launched. A "coming soon" page with a waitlist is public. Accounts, job posting, applications, an admin review queue and an AI job ad writer are built and tested, but only with my own test accounts. There are no real users, no payments and no outreach to clinics. Clinic sign up is by invitation only until launch. Target: a free launch in January 2027 at the earliest, only after the company, policy and other legal matters in this pack are settled. A blog is being written to build search ranking over time.

**The people.** I am the only founder and the only person with access. I am building Kestrel alongside other work. I am not a developer: the software is written by an AI coding assistant at my direction, and I review and approve it.

**Money.** Free launch for 30 to 60 days, then introductory prices of $39 (support staff), $49 (opticians) and $59 (optometrists) per 30 day post, then $79 a single post or $199 a month for a clinic pass (up to 5 live posts), with an annual option of $1,990. Prices are before HST. Payments (Stripe) are not built yet. Target revenue is $150,000 a year in 18 to 24 months, on running costs under $10,000 a year.

**What the product promises that has legal edges.** Every post must show a pay range (no more than $50,000 wide unless the top is over $200,000), say yes or no to "existing vacancy" and to "uses AI to screen candidates", and must not require "Canadian experience". Candidates apply through Kestrel; clinics see an application only after the candidate sends it. Later, Kestrel may list jobs it finds on clinics' own careers pages (labelled "found on the clinic's website, not yet claimed"), expire them after 21 days, and invite the clinic to claim them. That outreach is switched off.

## Who handles what

| Provider | What it does for Kestrel | Personal information it handles | Where |
|---|---|---|---|
| Supabase | Database, sign in, stored CVs | Accounts, profiles, applications, CVs, waitlist | Canada (Canada Central) |
| Vercel | Hosts the website and runs the server code | Everything that passes through a page or form | Server functions run in Montreal (set on 31st October 2026). The content delivery network is global |
| Resend | Sends email (sign up confirmations, alerts, application updates) | Recipient email address, message content | United States. Resend states that account data and logs are stored in the US whatever sending region is chosen |

| | | | |
|---|---|---|---|
| Anthropic | AI that drafts job ads for clinics | Only the job details a clinic types in; never candidate information | United States |
| Cloudflare | "Turnstile" bot check on forms | Browser signals | Cloudflare's global network |
| Google | Staff email (Workspace); optional "Continue with Google" sign in | Emails to hello@ and privacy@; sign in details | Google's data centres (not a Canada only service) |
| Namecheap | Domain registration | Registrant details (mine) | n/a |

I have accepted each provider's data processing terms. Stripe will be added at paid launch.

## Part B. The company and what it owns

7. Federal or Ontario corporation? Who should hold the shares? I may give a family member a private role, such as an emergency backup contact: does that have any legal consequences?. Name search (NUANS): can the legal name be Kestrel Eye Care Jobs, or should that be a registered business name?
8. Assignment to the company of everything Kestrel runs on: the domain (registered in my name at Namecheap), the logo and skyline artwork (my own), the website code (written by an AI coding assistant under my direction: who owns it, and is anything needed to make ownership clear?), and the accounts (Supabase, Vercel, GitHub, Resend, Anthropic, Google Workspace).
9. Trademark. Is a search and filing worthwhile for the name and the logo before launch? "Kestrel" is a common word and "Eye Care Jobs" is descriptive. Which classes, and how would you sequence this with incorporation? (I understand a company registration does not on its own protect a brand across Canada.)
10. Insurance: should the company carry cyber liability or professional liability cover before launch?
11. Which provincial and federal registrations are needed to operate? I am in Ontario. The mailing address in the footer, 6013 Yonge Street, 3rd Floor, North York, Ontario M2M 3W2, is a business or shared office address, and I am happy to publish it..

For my accountant, not the lawyer: HST registration timing (sales may pass $30,000 around month 10), Business Number, bank account, Stripe fees and how to restate the revenue model net of payment costs.

## Part C. The Terms, Posting policy and Privacy policy (Appendices A, B, C)

All three are plain English drafts, published with a "draft for review" banner (Terms and Posting policy). The Terms name no company. Email sign ups now agree to the terms and the privacy policy, and Kestrel records which version and when. I would like each reviewed and, where needed, rewritten.

12. The contracting party is only "Kestrel Eye Care Jobs". Who is it (corporation or sole proprietor), and what governing law and forum should apply?
13. The liability cap is "the amount you paid us in the last 12 months", which is $0 for every candidate, and for every clinic during the free launch. Is that acceptable, and what would you suggest?
14. There is no indemnity from clinics for their own posts or their use of applicants' data. Should there be?
15. Once a clinic opens an application, who is responsible for the applicant's personal information (Kestrel or the clinic)? How should the terms and the privacy policy say so? This also decides who answers an access request (question 23).
16. Listings Kestrel finds on a clinic's own website: what do the terms need to say, and how should a clinic have one taken down? Today only the claim page has a "remove it" email link.
17. The AI ad builder: the clinic must check a draft before posting and is responsible for it. Is the wording enough, and should the policy say more about how the AI is used?
18. "Using Kestrel after a change means you accept it" (Terms, near the end). Will that bind people, particularly consumers?
19. Fees and refunds, before prices switch on: refunds are not given if Kestrel removes a post for breaking the rules; the monthly pass renews automatically; there is an annual option; HST is added. What must the terms and checkout say (auto renewal disclosure, cancellation, refunds), and do clinics count as businesses or consumers here?
20. Remove the "draft" banners once reviewed. What version and date should be recorded as the agreed terms?
21. The privacy policy is out of date in places: it still says accounts and job posting are "still to come", and one sentence says we only email people who ticked the consent box, although job alerts go to people who set one up. Please correct these in your rewrite.

## Part D. Privacy and personal information

22. Where data is processed. The database and CVs are in Canada. The website's server functions now run in Montreal, but the content delivery network, Resend, Anthropic, Cloudflare and Google may process data elsewhere. How should the policy describe this, and are the providers' standard terms enough?
23. Access requests. "Download my information" gives a candidate their profile, applications, letters and alerts. It does not include a clinic's private notes about them, their waitlist entry or their email choices (the last two are being added). Must Kestrel hand over a clinic's notes, or can it refer the candidate to the clinic that wrote them?

24. Retention. Today everything is kept indefinitely. My proposal, for you to correct: unconfirmed waitlist sign ups 30 days; applications and their CV copies 2 years after the job ends; "let the clinic keep my details for future roles" 12 months unless renewed; job reports and listing claims 2 years; job posts 3 years. Ontario now requires employers with 25 or more employees to keep public job postings for 3 years: is that the clinic's duty only, or does Kestrel need to keep postings too?
25. Deleting accounts. At the moment, if a clinic deletes its account, its jobs and every application it received are deleted, and disappear from candidates' trackers; deleting a candidate removes their applications from clinics. I want to keep a candidate's own copy (title, clinic name, location, status) after a clinic leaves, and tell affected people. What should happen to each side, and for how long?
26. The privacy policy promises "a minimal record that we received and carried out your request" when someone deletes an account. Kestrel now records only the role and the number of jobs and applications, with no names or emails. Is that enough?
27. Quebec. Quebec can be selected everywhere, but there is no French and no Law 25 work. Option (a): keep Quebec out for now, showing "Quebec coming later". Option (b): do the work first (French terms and privacy policy, a privacy impact assessment for US services, an incident register). Which do you recommend, and what wording should (a) use?
28. The privacy officer. The policy says "our privacy officer" and privacy@eyecarejobs.ca. I plan to publish the title (Founder and Privacy Officer) and the contact address, and give the name on request. A backup person is named in the internal breach plan but not published. Is that enough for PIPEDA and for Quebec's requirement to publish the title and contact details?
29. The breach plan (Appendix D). Please review it, supply the lawyer's name and number, and say whether I should tell a clinic when its applicants' data is involved.
30. The consent wordings in Appendix E: the waitlist and sign up consent to "launch news, job alerts, product updates and offers"; the apply form's "let the clinic keep my details for future roles"; the job alert set up. Are they valid express consent under CASL and PIPEDA?

## Part E. Email and outreach (CASL)

31. Please review the clinic outreach email (Appendix E) before any is sent. It relies on implied consent: an address a clinic has published for hiring or business enquiries, and a message only about that role. It carries Kestrel's name, the mailing address and a working unsubscribe, processed at once. Is that basis sound for this use, and for generic addresses such as info@?
32. Job listings found on clinics' own careers pages. Copying facts is allowed but copying wording may not be; some clinic sites forbid automated copying. My rules: use only the clinic's own careers page, rewrite in our own words, link to the clinic's application page, never use its logo until claimed, expire after 21 days, recheck the page. Are these enough, and may Kestrel state "existing vacancy" and "uses AI to screen" for a clinic that has not told us? (I propose showing "Not stated by the clinic" until claimed.)
33. Unsubscribe links must keep working for 60 days after sending. I am keeping that, and adding a one click unsubscribe header. Anything else?

## Part F. Claims the product makes about the law

34. Kestrel's posting rules are built to match Ontario's job posting rules from 1st January 2026 (pay range, "existing vacancy", AI screening disclosure, no Canadian experience requirement) and British Columbia's pay range rule. Please confirm the rules as built are right: pay range at most $50,000 wide unless the top is over $200,000; hourly pay converted at 2,080 hours; the two yes or no questions; and a ban on any wording about Canadian experience. Are any over or under inclusive?
35. How may Kestrel describe this in its own marketing (for example, "helps you meet Ontario's rules") without promising compliance? Please suggest safe wording and a disclaimer.
36. Does Kestrel, as a job board, have any duty of its own under these rules, or do they fall only on the employer posting?
37. An idea for later: reminding Ontario clinics of the 45 day interview outcome duty and adding an accommodation notice to job pages and the apply form. Please suggest wording, and say whether offering it creates any duty for Kestrel.
38. Pay benchmark on the post a job form. While a clinic enters its pay range, Kestrel shows a line such as "Your range is in line with what is typical for opticians in Ontario", with the source and date. The figures come from the Government of Canada's Job Bank wages data (open.canada.ca, Open Government Licence – Canada, which I credit with the licence's own attribution statement and a link). Where Job Bank has no figure, I may show a range made by AI, labelled as a rough starting point, and later Kestrel's own posted pay once a role and province has at least 10 posts from at least 3 clinics. It is guidance only and never blocks a post. Does sharing pay benchmarks need any particular wording, limits or disclaimer? Please also say whether showing pay posted by other clinics, even as a combined median, raises any competition law concern (for example about employers sharing pay information), and whether the AI starting range should be shown at all.

## Part G. Smaller matters

39. Accessibility: I understand AODA's website rules apply from 50 employees and reporting from 20. Is a short accessibility statement still wise?
40. Analytics. I plan cookie free analytics and Google Search Console. Does that need any notice or consent?
41. Anything else a new Canadian online marketplace for regulated health professionals should have in place before launch that I have not asked about?

## Documents to bring

- This pack (the policies are in the appendices, exactly as published).
- A name search result, once done.

## Background 1. What the site collects, in short

| Who | What is collected | Why | Who sees it |
|---|---|---|---|
| Anyone on the waitlist | Name, email, province, role, clinic name (clinics), the consent wording and time | Launch news once Kestrel opens | Admin only |
| Candidate account | Name, email, password (or Google sign in), profession, licensed provinces, years of experience, availability, phone, a CV, job alerts | Apply to jobs and follow applications; job alerts | The candidate. A clinic sees an application only after the candidate sends it, as it was when sent |
| Application | Cover letter, CV copy, details sent, a copy of the job title and clinic name, status history | Apply | The clinic that received it; the candidate |
| Clinic account | Name, email, clinic profile, contact for alerts, confirmation of hiring directly (not an agency), jobs, templates, private notes about applicants | Post jobs and manage applicants | The clinic; admin for review |
| Reports and claims | Who reported or claimed a listing, their email, the reason | Safety and claiming listings | Admin only |
| Everyone | Terms version agreed and date; do not email list; a log of account deletions with no personal details | Records | Admin only |

Not collected today: payment details (Stripe will handle them), health information, government identifiers, tracking cookies.

## Background 2. Decisions already made, for information

- Clinic sign up is invitation only until launch; the board is not open.
- Marketing emails are only sent to people who ticked a consent box, plus job alerts that a person set up themselves.
- No scraping of Indeed, LinkedIn, Jobs4ECPs or the provincial college registers. Seeding, when it happens, uses clinics' own careers pages only.
- Row level security protects every database table. Account lock down (two step sign in) is in progress, and a security audit was completed on 30th October 2026.

## Appendix A. Terms of use, as published on 31st October 2026

Rendered from https://eyecarejobs.ca/terms. Navigation and footer removed.

# Terms of use

Last updated 30th October 2026

> **Draft for review.** This page is a working draft and has not yet been reviewed by a lawyer. It may change before Kestrel launches.

These terms are an agreement between you and Kestrel Eye Care Jobs ("Kestrel", "we" or "us"). They apply when you use eyecarejobs.ca, whether you are looking for a job or hiring. By creating an account or using the site, you agree to them. If you do not agree, please do not use Kestrel. Our privacy policy and posting policy are part of these terms.

## What Kestrel is

Kestrel is a job board for eye care in Canada. We help clinics share jobs and help candidates find and apply for them. We are not an employer, a recruiter or an employment agency. We do not choose who a clinic hires, and we cannot promise that anyone will be hired or that any job will lead to an interview.

## Your account

- You must be at least 16 years old to create an account.
- Give accurate information and keep it up to date. Do not create an account for someone else, or more than one account for yourself.
- Keep your password private. You are responsible for what happens under your account. Tell us at once if you think someone else has used it.

## If you are a candidate

- When you apply, the clinic that posted the job can see your application, including your cover letter, your CV and the details you chose to give. Only apply to jobs you are interested in.
- Make sure what you tell clinics is true, including your qualifications and registration.
- Clinic contact details are not shown on job posts. Please use Kestrel to apply, and do not try to collect clinic or staff contact details from the site.

- We may email you about your applications and, if you have agreed, about jobs and Kestrel news. You can unsubscribe at any time.

## If you are a clinic or a company

- You must be hiring directly for your own clinic or company. Recruiters, staffing agencies and job brokers may not use Kestrel to post jobs or to contact candidates.
- Every job you post must follow our posting policy. We read each post before it goes live, and we may ask you to change it, decline it, or remove it later.
- You are responsible for your hiring decisions and for following the laws that apply to you as an employer, including human rights, employment standards, pay transparency and privacy laws. Kestrel does not give legal advice.
- Use applicants' information only to assess them for the job they applied for, unless they agree to something more, such as being kept in mind for future roles.

## What you may not do

- Post or send anything false, misleading, discriminatory, unlawful or abusive.
- Use Kestrel as a recruiter, agency or broker, or to sell services to clinics or candidates without our written agreement.
- Ask a candidate for money to be considered for a job.
- Copy, scrape or collect jobs, candidate details or contact information from the site by automated means, or resell them.
- Send spam, or use Kestrel to contact people who have not applied to you for anything other than the job they applied for.
- Interfere with the site, try to get around its security, or use it in a way that harms others.

## Fees and payment

While Kestrel is in its free launch period, posting is free and these fee terms do not yet apply. When fees begin, we will say so on the site and by email before you are charged anything.

- Prices are shown in Canadian dollars before HST or other taxes. Tax is added at checkout and shown on your receipt.
- Payments are handled by Stripe, a payment company. We do not see or store your full card number.
- A single job post lasts 30 days from the day it goes live. A monthly clinic pass renews each month until you cancel, and you can cancel at any time. Cancelling stops the next renewal, and your pass stays active until the end of the period you have paid for.

- Once a post has gone live, its fee is not refundable. If we decline a post before it goes live, or a fault on our side stops it from being published, we will refund the fee or let you repost for free. If you think you were charged in error, write to us within 30 days.
- If we remove a post because it breaks these terms or our posting policy, we do not refund its fee.
- We may change our prices. A change applies to your next purchase or renewal, and we will give you notice first.
- Coupons and promotional codes have no cash value and may be withdrawn or have conditions, which we will state with the offer.

## Content you provide

You keep ownership of what you give us, such as job ads, clinic descriptions, CVs and cover letters. You give Kestrel permission to store it, display it on the site, and share it as needed to run Kestrel, for example showing a job post to visitors or sending your application to the clinic you applied to. You promise you have the right to give us this content. We may remove content that breaks these terms.

## Reporting problems

Anyone can report a job using the "Report this job" link on its page. We may take down a post while we look into a report. We may suspend or close an account that breaks these terms, and we will usually tell you why.

## Our content and brand

The Kestrel name, logo, design and the text and software that run the site belong to us. You may not copy them or use them in a way that suggests we support you, without our written permission.

## No guarantees, and limits on our responsibility

We work hard to keep Kestrel accurate and available, but we provide it "as is". We do not promise that it will always be available, error free or that every job, clinic or candidate is as described. We are not responsible for what clinics and candidates say or do, or for other websites that a job post links to. To the extent the law allows, Kestrel is not liable for indirect or consequential losses, or for losses beyond the amount you paid us in the 12 months before the problem arose. Nothing in these terms limits any rights you have under the law that cannot be limited.

## Ending your account

You can delete your account at any time from your account page. We may suspend or end access if these terms are broken, or if we must by law. Sections that by their nature should continue, such as those about payment and responsibility, continue after an account ends.

## Changes to these terms

We may update these terms. If a change matters, we will tell you by email or on the site before it applies. Using Kestrel after a change means you accept it.

## Law and contact

These terms are governed by the laws of Ontario and the federal laws of Canada that apply there. Disputes go to the courts of Ontario. Questions about these terms can go to hello@eyecarejobs.ca. See our contact page for our mailing address.

## Appendix B. Posting policy, as published

# Posting policy

Last updated 30th October 2026

> **Draft for review.** This page is a working draft and has not yet been reviewed by a lawyer. It may change before Kestrel launches.

This policy is for clinics that post jobs on Kestrel. It keeps the board honest and fair for candidates, and it keeps your post in good standing. It is part of our terms of use. We read every post before it goes live.

## Who may post

- Clinics and practices hiring directly for their own team, independent or corporate. Corporate groups may post for their own locations.
- Suppliers, manufacturers and optical labs hiring directly for their own team, including field based roles such as sales and territory representatives, trainers and clinical educators, and field service technicians.
- Outside recruiters, staffing agencies and job brokers may not post, and may not contact candidates through Kestrel. A corporate group's own recruiting or HR team may post for the group's own locations, because the group is the employer.
- You confirm this when you set up your clinic profile.

## What every post must include

- **A pay range** for the job, as a yearly salary or an hourly rate. The range should be genuine. Unless the top of the range is over $200,000 a year, it may not be more than $50,000 wide (hourly rates are counted over a standard year of 2,080 hours).
- **Whether this is an existing vacancy**, answered honestly with yes or no. Please do not advertise a job that does not exist.
- **Whether you use artificial intelligence to screen candidates**, answered honestly with yes or no.
- The role, the type of work (full time, part time, locum or contract), and the city and province. For a field based role, the city the person is based in and the area they cover.
- If part of the pay is commission, a car allowance or similar, say so. The pay range is still required, and it should show the base pay.
- A clear description of the job in your own words.

## What is not allowed

- **Discrimination.** Posts must not prefer or exclude people because of race, ancestry, colour, ethnic origin, citizenship, place of origin, religion, sex, gender identity or expression, sexual orientation, age, marital or family status, disability, or any other ground protected by human rights law. Please do not include wording about age, appearance, accent or family plans. Requirements must relate to the work, such as registration, qualifications and skills.
- **"Canadian experience" requirements.** Please do not ask for it. You may ask for the skills and qualifications the job needs.
- **Fees charged to candidates**, or any request for money, a deposit or banking details.
- **Misleading posts**: wrong pay, wrong location, a different job from the one described, or a job that is already filled.
- **Posts from agencies**, including "our client" or "confidential employer" posts.
- **Contact details in the text.** Please leave email addresses, phone numbers and web links out of the description. Candidates apply through Kestrel, or through a clinic application page you give us.
- Anything unlawful, offensive or unrelated to eye care hiring.

## How posts are reviewed

- Each post is read by our team before it is published. We may send it back to you with a note on what to change.
- A published post stays live for 30 days, then it expires. You can close it sooner, for example when the role is filled. In its last 7 days, or within 7 days of it ending, you can extend it for another 30 days with the same wording.
- A clinic can have up to 10 open jobs at a time (drafts, in review and live together). Monthly passes include up to 5 live posts.
- We may take down a post at any time if it breaks this policy, or after a report. We will tell you, and you can fix and resubmit it.

## Looking after applicants

- Please open and answer applications. Candidates can see whether you have viewed their application, and we remind you when applications have waited too long.
- When a job is filled or closed, update the status of the applicants so no one is left waiting.
- Use applicants' details only for hiring for the job they applied for, unless they agree to be kept in mind for future roles.

## If we remove a post or close an account

Repeated or serious breaches, such as posting as a recruiter, a scam, or discriminatory content, may lead to a suspended account. If you believe we made a mistake, write to hello@eyecarejobs.ca and a person will look at it.

## Appendix C. Privacy policy, as published

# Privacy policy

Last updated 5th November 2026

Kestrel Eye Care Jobs ("Kestrel", "we" or "us") is building a job board for eye care across Canada. This policy explains what personal information we collect when you join our waitlist, create an account or use this website, why we collect it, and the choices you have. We follow Canada's Personal Information Protection and Electronic Documents Act (PIPEDA) and Canada's anti-spam law (CASL).

## Who we are and how to reach us

Kestrel Eye Care Jobs
Email: privacy@eyecarejobs.ca

Our privacy officer looks after questions about this policy and about your personal information.

## What we collect

- **What you give us on the waitlist form:** your first name, your last name (optional), your email address, whether you are a clinic or looking for a role, your clinic name (clinics only), your role, and your province or territory. We then email you a link to confirm that the address is yours, and we keep the date you confirmed it.
- **If you create an account:** your name, your email address and whether you are a candidate or a clinic.
- **If you sign in with Google:** Google tells us your name and email address. We never see your Google password.
- **If you are a candidate:** the details you add to your profile (your role, where you are licensed, your experience, when you are available, and a phone number if you choose to give one), the CV you upload, and the cover letters and applications you send.
- **If you are a clinic:** your clinic's name, location, website and description, the job posts you write, and the private email address where you want to receive alerts.
- **Job alerts:** the roles, provinces and type of practice you choose, and how often you want an email.
- **If you report a job:** what you tell us about it and, only if you choose to give it, your email address so we can write back.
- **A record of your consent:** the exact wording you agreed to, and the date and time you agreed.
- **Basic technical information:** when you visit, our hosting provider records standard details such as your IP address, browser and the time of your visit. This is used for security and to keep the site running.

We do not currently use advertising cookies or tracking tools on this site. If that changes, we will update this policy and ask for your consent where the law requires it.

## Why we collect it

- To add you to our waitlist and email you about Kestrel Eye Care Jobs, including launch news, job alerts, product updates and offers.
- To run your account, let candidates apply to jobs, and let clinics review the applications they receive.
- To keep a record of your consent, as Canadian law requires.
- To keep the website secure and working.

We will not use your details for a different purpose without asking you first.

## Your consent and unsubscribing

We only email you if you ticked the consent box. You can withdraw your consent at any time by emailing privacy@eyecarejobs.ca or replying to any email from us. We will act on your request within 10 business days. Every marketing email we send will include an unsubscribe link.

If you unsubscribe, we keep your email address and the date on a suppression list so that we do not email you again by mistake.

## Who we share it with

We do not sell your personal information. We use a small number of service providers to run Kestrel. They handle your information only to provide their service to us:

- Supabase, which hosts our database and stored CVs in Canada.
- Vercel, which hosts our website.
- Resend, which sends our emails, such as sign up confirmations and application updates.
- Google, if you choose to sign in with it. Google is told when you sign in to Kestrel, and handles your sign in under its own privacy policy.
- Cloudflare, whose Turnstile security check on our forms tells real people from robots. It looks at signals from your browser, such as how it behaves, and does not need you to solve a puzzle in most cases.
- Anthropic, whose AI helps clinics write job ads. It sees only the job details a clinic types in, never candidate information.

**Clinics.** When you apply to a job, the clinic that posted it can see your application: your cover letter, your CV and the details you chose to give, as they were when you applied. It cannot see your profile otherwise, and clinics never see applications that were sent to other clinics.

**Candidates.** Clinic email addresses are never shown on job posts. Candidates apply to a clinic through Kestrel.

We may also disclose information when the law requires it.

## If you unsubscribe

We keep your email address, and nothing else about the email, on a do not email list, so that we honour your request in future. Even if you or your clinic post another job or join again by mistake, we will not send you marketing email. We will still send emails about an account or application you have, such as a new applicant or a password reset.

## Where your information is kept

Your details, CV and applications are stored in a database and a private file store hosted in Canada. Our website hosting provider, our email provider, our AI provider and our security check provider are based in the United States and may handle requests, and the emails we send you, on servers outside Canada. While your information is there, it may be subject to the laws of that country.

## How long we keep it

We keep your waitlist details while you are on the list, and your account, profile and CV while your account is open. You can replace or delete your CV in your profile at any time. If you ask us to delete your account, we will delete your profile, your CV and your applications, apart from a minimal record that we received and carried out your request, and the suppression record described above. A clinic that has already received your application may have kept its own copy of what you sent it, and you can ask us to ask that clinic to remove it.

## How we protect it

We limit who can see your details, store them in a database with restricted access, keep CVs in a private store that can only be opened through a link that works for 1 minute, use encrypted connections (HTTPS), and keep our access keys out of the website's public code. No system is perfectly secure. If a breach creates a real risk of significant harm to you, we will tell you and the Office of the Privacy Commissioner of Canada.

## Your rights

You can ask to see the personal information we hold about you, ask us to correct it, ask us to delete it, or withdraw your consent. You can download a copy of your information and delete your account yourself on the Account page, or email privacy@eyecarejobs.ca. We may need to confirm who you are first. If you are not satisfied with our response, you can contact the Office of the Privacy Commissioner of Canada.

## Changes to this policy

We will update this page as Kestrel grows, for example when we launch accounts, job posting and payments. The date at the top shows the latest version. If a change affects how we use your information in a way you have not agreed to, we will ask for your consent first.

# Appendix D. Breach plan (internal)

From the internal document docs/breach-plan.md. The backup person and the lawyer are to be filled in, and the backup person's name is deliberately kept out of this and every other document in the code repository.

# If personal information is lost or seen by the wrong person

One page. Keep it where you can find it quickly. A plain English summary of Canada's privacy law (PIPEDA), not legal advice. Alberta, British Columbia and Quebec also have their own rules, so ask the lawyer which apply. Read with `docs/security.md`.

**Privacy officer:** Steve Smith, privacy@eyecarejobs.ca

**Backup person:** held offline by Steve (in his password manager notes). Deliberately not written in this repository.

**Lawyer:** (add after the first meeting; keep the number in Steve's contacts, not here)

**Last reviewed:** 5th November 2026

## What counts

Any time personal information we hold (names, emails, phone numbers, CVs, cover letters, who applied where) is lost, or seen, taken or shared by someone who should not have it. Examples: a stolen key, a bug that shows one clinic another clinic's applicants, an email sent to the wrong list, a lost laptop with a downloaded spreadsheet, or a service we use telling us they were breached.

## What to do

**1. In the first hour: stop it getting worse.**

- Change the keys involved, most powerful first (`docs/security.md`). Sign people out if needed. Take down the page or switch off the feature.
- Write down the time you found out and who told you.

**2. The same day: write it down.** Add a line to the log below. Do this even if you are not sure it matters. Do not delete anything that might show what happened (logs, emails, deployments).

**3. Within a day or two: decide if it is serious.** The law asks whether there is a **real risk of significant harm** to the people involved. Think about:

- How sensitive is it? A CV and phone number is personal. A health record or bank detail would be worse. We hold no health or payment details.
- How likely is it to be misused? Was it taken on purpose by a criminal, or seen briefly by one trusted person who has deleted it? Was it scrambled so it cannot be read?
- How many people?

If you are not sure, treat it as serious and call the lawyer.

**4. If it is serious: tell people, quickly.**

- Report it to the **Office of the Privacy Commissioner of Canada** as soon as you can, using their online breach report form.
- Tell **each person affected** directly, by email. See the message below.
- If the people affected are candidates whose applications a **clinic** can see (or the reverse), also tell that clinic. Ask the lawyer who is responsible for the information once a clinic has opened an application.
- Tell anyone else who can help reduce the harm, if that applies.
- Ask the lawyer whether Alberta, British Columbia or Quebec's regulators also need to hear.

**5. Always: keep the record for 24 months,** including breaches that did not need reporting.

**6. Afterwards:** fix the cause, update `docs/security.md`, and tell the lawyer what changed.

## Four emergency switches (click by click)

For the first hour of step 1 above. Each one is reversible. Try the sign out and the email steps once on a quiet day against the **demo** project (sample data only), so you know what they do before you need them. Vercel and Supabase change their menus now and then. If a name below has moved, look for the closest one.

**1. Switch the whole site off (a "back soon" page)**

1. Vercel, open the `kestrel` project, Settings, Environment Variables.

2. Add `MAINTENANCE_MODE` with the value `yes`, for Production.

3. Deployments, open the latest Production deployment, the three dots, Redeploy.

4. To switch it back on: delete the `MAINTENANCE_MODE` variable and redeploy.

Every page and form shows the "back soon" page. `/api/health` and the daily job keep running. The demo site is a separate Vercel project, so do the same there if needed.

**2. Sign everyone out**

1. Supabase, open the project, SQL Editor.

2. Run: `delete from auth.refresh_tokens; delete from auth.sessions;`

3. People are asked to sign in again. A sign in that is already open can keep working until it expires, up to an hour, so switch the site off (switch 1) at the same time if this is a breach.

**3. Stop all email**

1. Resend, API Keys, delete the `kestrel-website` key. Everything the website sends stops, and the site keeps working.

2. Sign up emails go through Supabase, with a second Resend key (Supabase, Authentication, SMTP settings). Delete that key in Resend as well.

3. Make new keys afterwards and put them in Vercel and Supabase (`docs/security.md`).

4. A softer option: set `DAILY_EMAIL_BUDGET` to `0` in Vercel and redeploy. That stops only the daily job's emails (alerts and reminders).

**4. Go back to the last good version of the site**

1. Vercel, open the `kestrel` project, Deployments.

2. Find the last Production deployment that was fine, the three dots, Promote to Production (some plans call it Instant Rollback).

3. This does not undo database changes. Ask for help before changing the database back.

## What to say to the people affected

> Subject: An important message about your Kestrel information
>
> Hello [first name],
>
> We are writing to tell you about a security problem at Kestrel Eye Care Jobs. On [date], we found that [what happened, in plain words]. This involved your [what information, for example name, email address and CV].
>
> What we have done: [what you did to stop it and fix it].
>
> What you can do: [for example, be careful with unexpected emails that mention Kestrel, and change your password if you used the same one elsewhere].
>
> We are sorry. If you have questions, write to privacy@eyecarejobs.ca and a person will answer. You can also contact the Office of the Privacy Commissioner of Canada.
>
> The Kestrel team

Say what you know and what you do not know yet. Do not guess, blame or promise what you cannot be sure of.

## Breach log (keep one line per incident)

# Appendix E. Consent wordings, outreach email and the email list

## E1. Consent wordings saved with each sign up

| Where | Exact wording |
|---|---|
| Waitlist form and account sign up (optional box) | "Yes, email me launch news, job alerts, product updates and offers from Kestrel Eye Care Jobs. I can unsubscribe at any time." |
| Email sign up (required box) | "I agree to the terms of use and the privacy policy." |
| Google sign in, first visit (required box) | "I agree to the privacy policy and the terms of use." |
| Apply form (required) | "I agree that [clinic] can see this application, my CV and my details. Kestrel keeps them private from everyone else." |
| Apply form (optional) | "Optional: if this role is filled, let [clinic] keep my details for future roles. I can ask them to delete them at any time." |

## E2. The first email to a clinic whose job Kestrel has listed (switched off)

**Subject:** Your [job title] job is now on Kestrel Eye Care Jobs

Hello [clinic] team,

We are Kestrel Eye Care Jobs, a job board for eye care across Canada. We found the [job title] job on your own careers page ([source page]), and we have listed it on Kestrel so more eye care professionals can see it.

The listing is free. It is described in our own words, it is marked as not yet claimed, and every Apply button sends people straight to your own application page. We have not used your logo.

Advertising a job in more than one place helps more of the right people see it. Being on Kestrel does not replace or change anything on your own website or on other job boards, and there is nothing you need to do.

You can claim the listing to update it, add your pay range and see who is interested, or ask us to take it down and we will do so straight away. Just reply to this email.

We are writing to you because this address is published on your website for hiring and business enquiries, and this message is only about that job. If you would rather not hear from us, use the link at the bottom and we will stop.

Footer on every email: "You are receiving this because this address is published on your website for hiring enquiries." An unsubscribe link, and Kestrel's name and mailing address (6013 Yonge Street, 3rd Floor, North York, Ontario M2M 3W2).

## E3. Every email Kestrel sends

| Email | To | Kind | Basis | Unsubscribe |
|---|---|---|---|---|
| Confirm your waitlist email | The person who signed up | Marketing (a consent request counts) | Ticked box, wording saved | Link in footer |
| You're on the list | Confirmed sign up | Marketing | Ticked box plus confirmation | Link; do not email list checked |
| Job alert digest | Candidate | Treated as marketing | The alert the candidate set up | Signed link; list checked |
| Application updates and close out | Candidate | About their application | Not needed | Can be turned off in Account |
| New application, 14 day reminder | Clinic alert address | About their account | Not needed | Can be turned off |
| Job approved, needs a change, closes in 3 days | Clinic | About their account | Not needed | Closing soon respects the reminder choice |
| Job taken down; claim confirmed, approved, declined | Clinic or claimant | About their account or request | Not needed | None |
| Sign up, password reset, change email | Account holder | About their account | Not needed | None |
| Admin alerts | Steve (and a backup address if set) | Internal | n/a | None |
| Clinic outreach (E2) | Published hiring address | Marketing, implied consent | CASL s. 10(9)(b) | Signed link; list checked. Not yet sent to anyone |

Every email carries the sender's name, the mailing address and "The Kestrel team". Unsubscribes take effect immediately. Replies go to hello@eyecarejobs.ca.